

Monitoramento do Exchange Online — Detecção de Ameaças

Olá, meu nome é Cauã. Este documento apresenta a minha investigação prática sobre ataques direcionados ao Microsoft Exchange Online, conduzida utilizando o Splunk (SIEM).

📌 Para acessar diretamente a seção prática, [clique aqui](#).

📌 **Contexto** O e-mail é um vetor crítico em qualquer organização. Após comprometer uma caixa de correio, o invasor pode exfiltrar dados confidenciais e usar a conta legítima para disparar novas campanhas de *phishing* (agora vindo de uma fonte confiável). O foco desta documentação é o monitoramento de atividades **pós-comprometimento** — ou seja, rastrear o que o atacante faz após conseguir o acesso.

O que será abordado nesta investigação:

- Geração e mapeamento de logs do Exchange Online.
- Detecção de regras de caixa de correio suspeitas e encaminhamentos ocultos (*forwarding*).
- Identificação de campanhas de *phishing* lançadas a partir de contas internas comprometidas.
- Uso do rastreamento de mensagens e logs de auditoria para dimensionar o impacto do incidente.

Visão Geral do Exchange Online

O que é o Exchange Online

O Exchange Online é o serviço de e-mail e calendário baseado em nuvem da Microsoft, integrado ao pacote Microsoft 365 — também conhecido popularmente como Outlook. Diferente dos servidores Exchange locais tradicionais, que exigem que a própria organização gerencie sua infraestrutura de e-mail, o Exchange Online é totalmente hospedado e mantido pela Microsoft.

Por que o Exchange Online é um alvo valioso

O e-mail é uma peça essencial de qualquer organização: concentra comunicações comerciais confidenciais, dados financeiros, credenciais e informações pessoais. Isso faz do Exchange Online um alvo prioritário para invasores — uma vez dentro de uma caixa de correio, o atacante ganha acesso a uma verdadeira mina de informações e a uma plataforma poderosa para lançar novos ataques.

A Cadeia de Ataque Típica

Embora cada incidente seja único, pesquisadores de segurança e analistas de SOC identificaram um padrão recorrente em comprometimentos do Exchange Online:

1. **Roubo de Credenciais**

Antes de obter acesso, o invasor precisa de credenciais válidas. Isso geralmente ocorre por meio de e-mails de phishing, ataques de *credential stuffing* usando bases de senhas vazadas, ou pela compra de credenciais roubadas em mercados da dark web.

2. **Acesso Inicial**

Com as credenciais em mãos, o invasor se autentica no Microsoft 365 e acessa a caixa de correio da vítima. Essa autenticação é processada pelo **Entra ID** e deixa rastros nos logs de login.

3. **Descoberta**

Uma vez dentro, o invasor explora a caixa de correio: lê e-mails para entender a organização, identifica informações confidenciais, mapeia outros alvos em potencial e coleta dados que podem ser usados em ataques futuros.

4. **Persistência**

Para manter o acesso a longo prazo — mesmo que a vítima troque a senha — o invasor configura mecanismos para continuar recebendo dados. Isso inclui a criação de **regras de encaminhamento**, que copiam silenciosamente e-mails recebidos para um endereço externo, ou **regras de caixa de entrada** que excluem e-mails específicos para manter a vítima alheia ao comprometimento.

5. **Movimento Lateral**

Por fim, o atacante usa a conta comprometida como arma: ao enviar e-mails de phishing a partir de um endereço interno confiável, consegue contornar filtros de segurança de e-mail e enganar colegas para que cliquem em links maliciosos ou revelem suas próprias credenciais.

Nem todo invasor segue essa sequência à risca — algumas etapas podem ser puladas ou reordenadas. Ainda assim, compreender esse padrão dá aos analistas de SOC uma base sólida para investigar incidentes envolvendo o Exchange Online.

Próximos Passos

As próximas etapas desta investigação abordarão os logs gerados por cada uma dessas atividades, como detectá-los no **Splunk** e, por fim, a investigação de um comprometimento real do Exchange Online do início ao fim.

Fontes de Log para Investigação do Exchange Online

Nesta etapa entendi que investigar um comprometimento no Exchange Online não depende de uma única fonte de log — são **três fontes complementares**, e cada uma só enxerga uma parte da história. Juntando as três é que dá pra reconstruir o incidente de ponta a ponta.

Um detalhe prático que anotei: todas as consultas abaixo precisam ser rodadas com o intervalo "Todos os tempos" no Splunk, senão corro o risco de perder eventos relevantes.

Login: a porta de entrada

Toda vez que alguém acessa o Exchange Online, a autenticação passa primeiro pelo **Entra ID** — e isso acontece independentemente do login ter dado certo ou não. Entendi que é exatamente por isso que esse log é valioso: ele registra tanto tentativas bem-sucedidas quanto falhas, o que permite ver não só quem entrou, mas também quem *tentou* entrar e não conseguiu.

A partir dele dá pra responder: quem tentou acessar, de qual IP e localização, e se a tentativa foi aceita ou rejeitada.

```
spl
index=* sourcetype="azure:aad:signin" appDisplayName="One Outlook Web"
| table _time userPrincipalName appDisplayName ipAddress location.city status.errorCode
| sort - _time
```

Auditoria unificada: o que a pessoa fez depois de entrar

O login sozinho não conta muita coisa — ele só confirma o acesso. O que o invasor faz *depois* de entrar fica registrado nos **logs de auditoria unificados do M365**. É aqui que aparecem e-mails enviados, regras de caixa de entrada criadas ou alteradas, mudanças de configuração e acessos à caixa de correio.

```
spl
index=* sourcetype="o365:management:activity" Workload=Exchange
| table _time UserId Operation Workload
```

Percebi que dois campos sustentam essa consulta: **Workload**, que identifica o serviço do M365 que gerou o evento (para o que nos interessa aqui, sempre **Exchange**), e **Operation**, que diz exatamente qual ação foi tomada. Dentro desse log existem várias operações possíveis, mas separei as que considero mais decisivas para uma investigação:

Operação	O que indica
MailItemsAccessed	O invasor leu e-mails da caixa comprometida
Send	Um e-mail foi enviado — possível phishing partindo de conta interna
New-InboxRule / Set-InboxRule	Regra criada ou alterada para esconder rastros (ex: excluir respostas, encaminhar e-mails)
Set-Mailbox	Configuração da caixa alterada — inclui encaminhamento silencioso para fora
Add-MailboxPermission	Acesso delegado concedido — forma comum de persistência, já que sobrevive a uma troca de senha

O ponto que me chamou atenção aqui é justamente esse último: um invasor pode se dar permissão de acesso à caixa, e isso continua valendo mesmo que a vítima troque a senha depois. Ou seja, redefinir senha sozinho não resolve.

Rastreamento de mensagens: o destino que a auditoria não mostra

Essa foi a parte que fez mais sentido pra mim: a auditoria mostra que um e-mail *foi enviado*, mas não diz **quem recebeu**. É exatamente essa lacuna que o rastreamento de mensagens cobre — ele acompanha a entrega completa de cada e-mail: remetente, destinatário, assunto, status e horário.

spl

```
index=* sourcetype="o365:reporting:messageTrace"
```

```
| table Received SenderAddress RecipientAddress Subject Status FromIP
```

Entendi que essa fonte serve principalmente para duas coisas: confirmar o alcance de uma campanha de phishing (quantas pessoas receberam e se a entrega foi concluída) e ajudar a montar a linha do tempo do incidente com base em horários precisos de entrega — já que os outros dois logs sozinhos não dão essa granularidade.

Persistência no Exchange Online: Regras de Caixa de Entrada, Encaminhamento e Delegação

Depois do acesso inicial, o invasor muda de prioridade: precisa continuar recebendo dados sem levantar suspeita. Para isso, costuma abusar de três recursos legítimos do Exchange Online — regras de caixa de entrada, encaminhamento de e-mail e acesso de delegados.

Regras de Caixa de Entrada

Regras de caixa de entrada são um recurso normal (mover newsletters, sinalizar e-mails, etc.), mas servem bem aos interesses de um invasor. No Splunk aparecem como **New-InboxRule** (regra nova) ou **Set-InboxRule** (regra modificada).

Invasores costumam usar dois tipos:

- **Regras de exclusão:** apagam automaticamente respostas de colegas desconfiados de um phishing enviado pela conta comprometida.
- **Regras de encaminhamento condicional:** encaminham só e-mails com palavras específicas ("fatura", "pagamento", "credenciais") para fora, evitando volume suspeito.

UserId ↕	Name ↕	DeleteMessage ↕	ForwardTo ↕	SubjectContainsWords ↕
robert.green@techcorp.thm	Maintenance	True		Alert
james.wilson@techcorp.thm	Cleanup		fowr54wwr@protonmail.com	Verify
james.wilson@techcorp.thm	WorkreLated2	True		

Splunk SPL

```
index=* Workload=Exchange Operation=New-InboxRule | table _time UserId Name  
DeleteMessage ForwardTo SubjectContainsWords
```

Campo	Indica
Name	Nome da regra
SubjectContainsWords	Condição de disparo
DeleteMessage	Se True, exclui o e-mail
ForwardTo	Encaminha para outro endereço

Com essa consulta:

- Nome da regra que encaminha para endereço externo? → **Cleanup**
- Palavra que aciona a regra no assunto? → **Verify**

O alerta mais grave é **DeleteMessage = True** — raramente legítimo.

*Observação: no **Set-InboxRule**, o log só registra os campos que mudaram, não a regra completa.*

Sinais de alerta gerais: **DeleteMessage=True**; **ForwardTo** externo; regras criadas fora do horário comercial; nomes genéricos disfarçando a regra.

Encaminhamento em Nível de Caixa de Correio

Diferente das regras acima (condicionais), esse encaminhamento é incondicional — todo e-mail recebido é copiado para fora. Configurado nas configurações da caixa, aparece como **Set-Mailbox**.

UserId ↕	ForwardingSmtpAddress ↕	DeliverToMailboxAndForward ↕
robert.green@techcorp.thm	smtp:x7tpq2m@protonmail.com	False
NT SERVICE\MSExchangeAdminApiNetCore (Microsoft.Exchange.AdminApi.NetCore)		
NT SERVICE\MSExchangeAdminApiNetCore (Microsoft.Exchange.AdminApi.NetCore)		
NT SERVICE\MSExchangeAdminApiNetCore (Microsoft.Exchange.AdminApi.NetCore)		
james.wilson@techcorp.thm	smtp:d4rui6g@protonmail.com	True
james.wilson@techcorp.thm	smtp:d4rui6g@protonmail.com	False

SPL

```
index=* Workload=Exchange Operation=Set-Mailbox | table _time UserId
ForwardingSmtpAddress DeliverToMailboxAndForward
```

Com essa consulta:

- Para qual endereço externo os e-mails foram encaminhados? → **d4ruy6g@protonmail.com**

Sinais de alerta: domínio externo (Gmail, ProtonMail); **DeliverToMailboxAndForward=False** (a vítima nem recebe cópia); configurado logo após login suspeito.

Acesso de Delegados

Técnica menos comum, mas igualmente eficaz: o invasor se adiciona como delegado da caixa da vítima, ganhando acesso interativo total (ler, enviar, gerenciar) que sobrevive até a troca de senha. Aparece como **Add-MailboxPermission**, com o campo **Trustee** mostrando quem recebeu o acesso.

Remediação

- Excluir regras suspeitas.
- Remover encaminhamentos não autorizados.
- Forçar redefinição de senha.
- Revogar tokens e sessões ativas.
- Checar por quanto tempo o encaminhamento ficou ativo e o que pode ter sido exfiltrado.
- Remover delegados inesperados.

Detecção de Phishing via Caixa de Correio Comprometida

Com persistência já estabelecida, o invasor usa a caixa comprometida como arma: e-mails de phishing enviados por uma conta interna legítima ignoram filtros externos e têm muito mais chance de serem clicados.

MailItemsAccessed — Reconhecimento Antes do Ataque

Antes de atacar, o invasor costuma ler e-mails da vítima para criar phishing convincente, referenciando projetos e colegas reais. Isso fica registrado na operação

MailItemsAccessed.

UserId ↕	ClientIPAddress ↕	OperationCount ▼ ↕
emma.clarke@techcorp.thm	197.32.45.112	8
robert.green@techcorp.thm	217.138.209.30	8
emma.clarke@techcorp.thm	2603:10a6:20b:63b::18	7
emma.clarke@techcorp.thm	138.199.21.212	5
robert.green@techcorp.thm	138.199.21.211	5
robert.green@techcorp.thm	197.32.45.112	5
james.wilson@techcorp.thm	2603:10a6:20b:5ac::8	4
james.wilson@techcorp.thm	197.32.45.112	4
emma.clarke@techcorp.thm	2603:10a6:20b:63b::18	4

spl

index=* Workload=Exchange Operation=MailItemsAccessed

| table _time UserId ClientIPAddress OperationCount

Relevante também para avaliar exposição de dados (obrigação de notificação sob GDPR, se e-mails sensíveis foram acessados).

Sinais de alerta: IP/local incomum; **OperationCount** alto; acesso fora do horário comercial.

Operação Send — E-mails Enviados pelo Invasor

Cada phishing enviado pela conta comprometida gera uma operação **Send**.

Campo	Descrição
UserId	Conta que enviou
Item.Subject	Assunto do e-mail
ClientIP	IP de envio
SaveToSentItems	Se foi salvo em Itens Enviados

UserId ↕	Item.Subject ↕	ClientIP ↕	SaveToSentItems
emma.clarke@techcorp.thm	Weekly Report	197.32.45.112	true
emma.clarke@techcorp.thm	HR Policy Reminder	197.32.45.112	true
robert.green@techcorp.thm	Report Update	197.32.45.112	true
james.wilson@techcorp.thm	Meeting Agenda	197.32.45.112	true
james.wilson@techcorp.thm	Project Documentation	197.32.45.112	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true

spl

index=* Workload=Exchange Operation=Send

| table _time UserId Item.Subject ClientIP SaveToSentItems

Com essa consulta: **qual foi o assunto do e-mail suspeito recebido por um colega?** → **Urgent: Verify Your Account**. E pelo campo **ClientIP**: **de qual IP os e-mails suspeitos foram enviados?** → **190.2.149.93**.

SaveToSentItems=False é bandeira vermelha — esconde o e-mail da pasta Enviados da vítima.

Sinais de alerta: alto volume de **Send** em pouco tempo; **SaveToSentItems=False**; IP diferente do login normal; assuntos suspeitos (faturas, senha, urgência).

Rastreamento de Mensagem — Alcance da Campanha

O **Send** mostra que o e-mail saiu, mas não quem recebeu. Para isso, volta-se ao rastreamento de mensagens.

spl

```
index=* sourcetype="o365:reporting:messageTrace"
```

```
| table Received SenderAddress RecipientAddress Subject Status FromIP
```

Filtrando pelo remetente e assunto do phishing, dá pra responder: **quantos colegas receberam o e-mail?** → **2**.

Sinais de alerta: vários destinatários do mesmo e-mail em curto espaço de tempo; **Status=Delivered**; destinatários de departamentos diferentes (campanha ampla).

Remediação

1. Bloquear a conta comprometida imediatamente
2. Identificar todos os destinatários via rastreamento de mensagens
3. Notificar os destinatários (não clicar em links/anexos)
4. Verificar se há outras contas comprometidas (quem respondeu ou clicou)
5. Revisar a pasta de Itens Enviados da conta em busca de outros e-mails suspeitos

Investigação Prática: Caso Robert Green — TechCorp

Cenário

Um alerta de login incomum para **Robert Green**, gerente financeiro da TechCorp, foi triado por um analista Nível 1 e escalado para mim (Nível 2) por ter se originado de um **local desconhecido**. Todos os funcionários da TechCorp trabalham na mesma rede de escritório — qualquer login fora dela já é um desvio de padrão.

Vou usar **index=task6**, intervalo "All Time", e ordenar sempre por **| sort - _time** para reconstruir a linha do tempo do invasor na ordem correta.

Passo 1 — Confirmar o Login Suspeito

Primeiro ponto de verificação: de onde veio esse acesso. Volto aos logs de login do Entra ID para localizar o evento e extrair localização e IP de origem.

spl

```
index=task6 sourcetype="azure:aad:signin" userPrincipalName="robert.green@*"
```

```
| table _time userPrincipalName appDisplayName ipAddress location.city status.errorCode
```

```
| sort - _time
```

userPrincipalName	appDisplayName	ipAddress	location.city
robert.green@techcorp.thm	One Outlook Web	217.138.209.30	Ursynow
robert.green@techcorp.thm	One Outlook Web	217.138.209.30	Ursynow
robert.green@techcorp.thm	One Outlook Web	217.138.209.30	Ursynow
robert.green@techcorp.thm	One Outlook Web	217.138.209.30	Ursynow

Como todos os funcionários trabalham na mesma rede, qualquer `location.city` diferente da sede já confirma a anomalia.

Pergunta: de qual cidade o login malicioso foi realizado?

Resposta: Ursynow

Passo 2 — Verificar Persistência (Regra de Caixa de Entrada)

Com o acesso confirmado, o próximo movimento esperado do invasor é garantir persistência. Busco criação de regras na caixa de Robert logo após o horário do login suspeito.

spl

```
index=task6 Workload=Exchange Operation=New-InboxRule UserId="robert.green@*"
```

```
| table _time UserId Name DeleteMessage ForwardTo SubjectContainsWords
```

```
| sort - _time
```

UserId	Name	DeleteMessage	ForwardTo	SubjectContainsWords
robert.green@techcorp.thm	Maintenance	True		Alert

Pergunta: qual era o nome da regra de caixa de entrada suspeita criada pelo invasor?
Resposta: Maintenance

Passo 3 — Verificar Encaminhamento em Nível de Caixa de Correio

Além da regra, verifico se o invasor também configurou encaminhamento incondicional — prática comum para garantir que nada escape, mesmo que a regra seja descoberta e removida.

spl

index=task6 Workload=Exchange Operation=Set-Mailbox UserId="robert.green@*"

| table _time UserId ForwardingSmtpAddress DeliverToMailboxAndForward

| sort - _time

UserId ↕	ForwardingSmtpAddress ↕	DeliverToMailboxAndForward ↕
robert.green@techcorp.thm	smtp:x7tpq2m@protonmail.com	False

Pergunta: para qual endereço estava configurado o ForwardingSmtpAddress?
Resposta: x7tpq2m@protonmail.com

Passo 4 — Rastrear o Phishing Enviado aos Colegas

Confirmada a persistência, o passo seguinte da cadeia é a arma de movimento lateral: phishing disparado da própria conta de Robert para os colegas, explorando a confiança interna.

spl

index=task6 Workload=Exchange Operation=Send UserId="robert.green@*"

| table _time UserId Item.Subject ClientIP SaveToSentItems

| sort - _time

UserId ↕	Item.Subject ↕	ClientIP ↕	SaveToSentItems ↕
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true
robert.green@techcorp.thm	Action Required: Password Reset	138.199.21.211	true

Pergunta: qual era o assunto do e-mail de phishing recebido pelos colegas de Robert?

Resposta: Action Required: Password Reset

O campo **ClientIP** dessa mesma consulta revela a origem do envio — e nesse caso, pelo enunciado, tudo indica uso de VPN pelo invasor.

Pergunta: de qual endereço IP o invasor enviou os e-mails de phishing?

Resposta: 138.199.21.211

Passo 5 — Medir o Alcance: Quem Recebeu e Quem Respondeu

Por fim, uso o rastreamento de mensagens para fechar o escopo do incidente: quem recebeu o e-mail e, mais crítico ainda, quem **respondeu** — já que uma resposta pode indicar uma segunda conta potencialmente comprometida.

spl

index=task6 sourcetype="o365:reporting:messageTrace"

| table Received SenderAddress RecipientAddress Subject Status FromIP

| sort - Received

robert.green@techcorp.thm	emma.clarke@techcorp.thm	Action Required: Password Reset	Delivered
james.wilson@techcorp.thm	emma.clarke@techcorp.thm	Project Documentation	Delivered

Para identificar quem respondeu, reviso o rastreamento filtrando pelos destinatários como novos remetentes em sequência próxima ao e-mail original (resposta gera um novo evento de envio, agora partindo da conta do destinatário).

Pergunta: um dos destinatários respondeu ao e-mail de phishing. Qual usuário respondeu?

Resposta: emma.clarke@techcorp.thm

Linha do Tempo Reconstruída

Seguindo a ordem cronológica que a consulta | **sort - _time** me garante, a cadeia do incidente ficou assim:

1. Login suspeito de localização incomum
2. Criação de regra de caixa de entrada para ocultar atividade
3. Configuração de encaminhamento incondicional para exfiltração contínua
4. Envio de phishing para colegas, abusando da confiança interna

5. Pelo menos um colega respondeu — possível segunda conta comprometida

Conclusão

Este é o fim da documentação da sala de Monitoramento do Exchange Online.

Ao longo desta investigação, vi como invasores abusam do Microsoft Exchange Online depois de comprometer uma caixa de correio: desde a identificação de logins suspeitos usando os logs do Entra ID, passando pela detecção de abuso de regras de caixa de entrada e encaminhamento de e-mail através dos logs de auditoria do Exchange, até identificar campanhas de phishing lançadas a partir de contas comprometidas e avaliar o impacto total de um ataque usando rastreamento de mensagens.

Obrigado por ler e acompanhar esta investigação!